

7.15 D-G audit — groups and visible optional fields

1. Identity and frozen scope

Sole audit agent: Codex. Worktree /private/tmp/kk715-dg, branch release/715-stack-07b2a-erc7730-groups. Owner explicitly authorized the two-part D split on 2026-09-27. Target is A–C draft PR #865 at 5c0090e038769ed36d627d4dca09cbfcb1df91d3. Code predecessor: d30ee3d46; containing final SHA is recorded in the PR body. This is a code-bearing adjacent unit. Historical PR #866 is preserved. Canonical release remains release/7.15; no product ref is updated here. Python companion PR #117 pins b9858363c0ab087d47f7c115f46a2e0d741131fb. Other dependencies retain the exact A–C pins (listed below).

The unit enables balanced display groups (opcodes 5/6) and optional visibility (condition 3). Optional means always shown, including zero-valued fields. Iteration, conditional hiding and embedded calls remain refused at this boundary. Group frames use separate storage so nesting cannot overwrite path classes.

2. Git inventory and changed behavior

Inventory is regenerated against the immutable report predecessor recorded 38623431a. The final source/PDF are regenerated after that predecessor. No overlapping historical counts are summed. The original D delta is divided by behavior in the adjacent split mapping receipt.

Tracked path	Added	Deleted	Change and evidence
.github/workflows/ci.yml	1	1	Changed as part of this bounded audit unit.
deps/python-keepkey	1	1	Pins the matching compiler mirror and its tests.
docs/release/audit-units/715-07b-d-resplit-mapping-20260927.md	42	0	Records exact scope, findings, inventory and validation.
docs/release/audit-units/715-07b2a-groups-audit-20260927.md	119	0	Records exact scope, findings, inventory and validation.
docs/release/audit-units/715-07b2a-groups-audit-20260927.pdf	-	-	Rendered audit evidence from the adjacent source report.
include/keepkey/firmware/erc7730_capabilities.h	7	4	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_catalog.h	1	0	Declares bounded state and the phase's runtime contract.
lib/firmware/erc7730_capabilities.c	5	1	Selects the exact formatter and display capabilities.
lib/firmware/erc7730_catalog.c	4	3	Refuses unexecutable signed programs before review.
lib/firmware/fsm_msg_ethereum.h	11	0	Shows and confirms the device-decoded review screens.
scripts/emulator/test_stack07_regressions.py	20	3	Exercises signed wire requests and review screens.
unittests/firmware/erc7730_catalog.cpp	113	76	Covers accepted neighbors and fail-closed boundaries.

Capabilities select groups and optional visibility. Catalog validation requires supported conditions and balanced frame links. The signing dispatcher advances through groups while retaining each field. Native tests exercise structural boundaries and frame isolation. Wire tests require every nested optional field, including zeros, and retain unsupported conditional-visibility refusal. The workflow companion URL now names this unit's actual pinned Python PR.

3. Source reconciliation and findings

- DG-01 fixed: group nesting previously reused signature scratch holding path classes. Separate bounded frames preserve those classes. The focused native regression passes, fails when both frame pointers use signature storage, and passes again after restoring the fix.
- DG-02 fixed: inherited wire refusal treated groups as unsupported. Removed that obsolete expectation; conditional visibility remains refused. A positive wire case checks nested groups and both zero/nonzero optional values.
- DG-03 verified: signer-owned constants are legal fields but forbidden intent values. Added host/device regression. During downstream extraction the old D mirror's tuple-index bug was identified; its repair belongs to D-I.
- D review findings: active-array binding, failed capture count and fixed-array screens belong to D-I. Stale registry-count reporting is reconciled separately at each boundary. No historical review result is transferred to this child.
- Evidence limitation: the original 42-entry raw finding manifest was not retained. Historical D13/D19 identifiers cannot be reconstructed reliably. Preserved summaries do not establish an independent audit after every old round.

Local source audit traced condition masks, balanced group links, depth bounds, frame lifetime, dispatcher continuation and all retained field screens. Groups never suppress fields or create an approval bypass. The source does not add iteration runtime. Existing parser/refusal tests remain in the native suite.

4. Verification and artifact identity

Local validation uses pinned Docker image `kktech/`

`firmware@sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2`. Firmware code/test snapshot is `d30ee3d46`; subsequent changes record evidence and correct the report companion URL only.

Check	Result	Evidence and limits
Full native firmware	650 passed	firmware-unit, all suites; dg-native.xml
Compiler/validator	16 passed, zero skips	registry 9f37816afde954ff6617fb5baa346133e5af26c5; 1,450 formats checked, 1,221 signable
Stack07 full emulator wire	37 passed	dg-wire.xml; public test mnemonic and throwaway signing key
Frame-storage negative control	expected failure then pass	GroupFramesPreservePathClasses; original source restored
Host/device signer-constant contract	passed	legal field neighbor and rejected intent mutation
Exact-head hosted CI	pending at freeze	PR records run/head; required before review
ARM, Bitcoin-only and full host evidence	pending child CI	predecessor evidence is supporting only
Physical device	not performed	still required before release

Exact pins retained from A–C: code-signing-keys `a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec`; trezor-firmware `8a392f70a5d5575ece3dfb35f115d4a4b27f497c`; device-protocol `5fec9e6906a340be5eb3d795ec746769065b2db8`; googletest `7888184f28509dba839e3683409443e0b5bb8948`; QR-Code-generator `6dfbfad5d9303ed190d1c3cb7bec34b565b6ce8`; SecAESSTM32 `71d356a1141624994cf613bd2d2583892e8e6d5a`.

5. Render and preflight

Source and adjacent PDF are rendered together and all pages visually inspected. Final inventory, whitespace, workflow lint, pinned clean dependencies and code-bearing gate must be checked before push. Empty-diff negative control must fail. Canonical preflight retains the previously owner-authorized exceptions: duplicate Osmosis/Solana nanopb options, missing inherited report-gate test, and `cppcheck`'s absent build directory. That gate is failed, not called passing; hosted static analysis and report/evidence gates must pass on the final head.

6. Review checkpoint and retrospective

Zero child Copilot requests at freeze; fresh budget is at most three attempts. No review is requested before exact-head hosted evidence is green. Findings require class-wide audit, dispositions, full preflight and fresh CI before the next request. Historical PR #866 exhausted its attempts and stays preserved. The split narrows groups away from array execution. The obsolete refusal test caught here shows why each boundary needs its own contract and registry count. D-I and E-R remain separate children; no merge or release acceptance is claimed.